SUBJECT	VULNERABILITY ANALYSIS
CODE	IKB21004 & IKB21403
TASK	FILE ANALYSIS – SCANNING RESULT

Question 1: Analyse packet1.pcap and find the flag.

36	17.023696	171.64.20.62	172.24.20.31	ICMP	98 Echo (ping) reply id=0x7a93, seq=18/4608, ttl=64 (request in 35)
37	17.313236	172.24.20.31	171.64.20.62	ICMP	70 Echo (ping) reply id=0x0001, seq=0/0, ttl=63
38	18.025681	172.24.20.31	171.64.20.62	ICMP	98 Echo (ping) request id=0x7a93, seq=19/4864, ttl=63 (reply in 39)

Packet 37

```
Sequence Number (LE): 0 (0x0000)
▾ Data (28 bytes)
    Data: 55315644564559794d44497a6532467058326c7a58324e7662327839
    [Length: 28]
```

Found hex data string.

```
0000  00 0c 29 58 4f 6e b4 0c  25 ea 40 10 08 00 45 00   ··)XOn·· %·@···E·
0010  00 38 02 2d 00 00 3f 01  f9 e2 ac 18 14 1f ab 40   ·8·-··?· ·····@
0020  14 3e 00 00 1c a8 00 01  00 00 55 31 56 44 56 45   ·>····· ··U1VDVE
0030  59 79 4d 44 49 7a 65 32  46 70 58 32 6c 7a 58 32   YyMDIze2 FpX2lzX2
0040  4e 76 62 32 78 39                                  Nvb2x9
```

Highlighted hex and ASCII string.

Decode from Base64 format

Simply enter your data then push the decode button.

U1VDVEYyMDIze2 FpX2lzX2Nvb2x9

For encoded binaries (like images, documents, etc.) use the file upload form a little further down on this page.

UTF-8 Source character set.

Decode each line separately (useful for when you have multiple entries).

Live mode OFF Decodes in real-time as you type or paste (supports only the UTF-8 character set).

DECODE Decodes your data into the area below.

SUCTF2023{ai_is_cool}

Translated ASCII to base64 format.

Flag = SUCTF2023{ai_is_cool}

Question 2: Analyse packet2.pcap and find the flag.

Reading ASCII string data of each packet.

packet 22 = Hello
packet 32 = How are you?
packet 70 = Are you a robot?
packet 329 = Did you ever play tic-tac-toe?
packet 409 = Yeah, of course.
packet 505 = But you don't play anymore?
packet 535 = No
packet 587 = Why?
packet 651 = Because it's a boring game. It's always a tie.
packet 720 = Exactly. There's no way to win.
packet 774 = The game itself is pointless.

Packet 156 - 235 describes an FTP login session.
Packet 205 = Mentions a txt filed named "Global_thermonuclear_war.gamerules.txt"
Packet 216 = Mentions a url that leads to a google doc

Decipher using tic-tac-toe code gets = EWMACHINAAVA

Question 3: Interpret an Nmap Output

```
PORT    STATE SERVICE VERSION
21/tcp  open  ftp     vsftpd 2.3.4
22/tcp  open  ssh     OpenSSH 5.3p1
80/tcp  open  http    Apache 2.2.8
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds Windows 7 Professional 7601 Service Pack 1
```

Questions:

1. What can an attacker do with each port?

   Port 21 (FTP) = **File Transfer Protocol (FTP) port** is used for transmitting both commands, and data, including login credentials, in plain text. Attackers can use this to sniff, intercept, and many other attacks.

   Port 22 (SSH) = **Secure Shell (SSH) port** is widely used for secure file transfers and server management tasks. An exposed port 22 allows automated botnets to perform brute-force attacks, credential guessing, and vulnerability exploits.

   Port 80 (HTTP) = **HyperText Transfer Protocol (HTTP) Port** is used to transmit data in unencrypted plaintext. Attackers can use this to perform sniffing, session hijacking, and man-in-the-middle attacks.

   Port 139/445 (SMB) = **Server Message Block (SMB) protocol** is for file and printer sharing in Windows networks. Access to this port allows the attacker to gain full administrative control over the system without needing any credentials

2. What vulnerabilities are likely present based on the version?

Port	Service	Version	Known Vulnerability
21/tcp	vsftpd	2.3.4	Prone to backdoor vulnerability. An attacker can cause the application to open a backdoor on port 6200 by logging to the FTP server with the username ':)'
22/tcp	OpenSSH	5.3p1	Remote code execution, information leakage, and denial of service.
80/tcp	Apache	2.2.8	According to CVE-2008-2364, this version is vulnerable to denial of service.
445/tcp	Windows 7 Professional 7601	Service Pack 1	Known as "EtetnalBlue". This vulnerability allows for remote code execution via the SMBv1 protocol, which can lead to complete system compromise.

3. Which one is the highest risk and why?

- Based on the table above, the highest risk vulnerability would be port 445 (SMB) as it poses the highest impact exploit that provides the attacker to escalate their privileges to the system level instantly.

4. What attack path can be built from this?

1. Accessing backdoor through vsftpd 2.3.4 or MS17-010 EternalBlue to gain initial shell
2. Create a new user
3. Escalate privilege to administrative
4. Extract user credentials
5. Use other user credentials to move between system in the network

5. What should be the remediation?

- Frequent OS updates whenever available to avoid being vulnerable to known vulnerabilities on older versions.
- Disable unnecessary port services that are not used.

Question 4: Identify the OS (OS Fingerprinting) - TTL

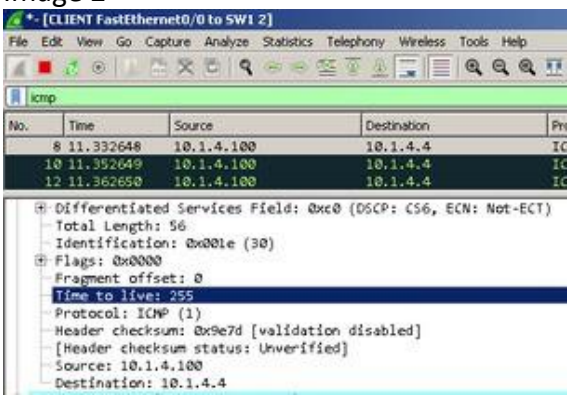
Image 1

```
[sk@ostechnix ~]$ ping -c5 localhost
PING localhost(localhost (::1)) 56 data bytes
64 bytes from localhost (::1): icmp_seq=1 ttl=64 time=0.063 ms
64 bytes from localhost (::1): icmp_seq=2 ttl=64 time=0.057 ms
64 bytes from localhost (::1): icmp_seq=3 ttl=64 time=0.070 ms
64 bytes from localhost (::1): icmp_seq=4 ttl=64 time=0.067 ms
64 bytes from localhost (::1): icmp_seq=5 ttl=64 time=0.056 ms

--- localhost ping statistics ---
5 packets transmitted, 5 received, 0% packet loss, time 4096ms
rtt min/avg/max/mdev = 0.056/0.062/0.070/0.005 ms
```

Answer: Linux

Image 2



Answer: Solaris

Image 3:

```
64 bytes from 192.168.122.239: icmp_seq=1 ttl=128 time=6.85 ms
64 bytes from 192.168.122.239: icmp_seq=2 ttl=128 time=0.510 ms
64 bytes from 192.168.122.239: icmp_seq=3 ttl=128 time=0.601 ms
64 bytes from 192.168.122.239: icmp_seq=4 ttl=128 time=0.541 ms
64 bytes from 192.168.122.239: icmp_seq=5 ttl=128 time=0.558 ms
```

Answer: Windows

Question 5: Analyse the Nessus file

Upload to your nessus (Network_Scan.nessus) and analyse the files. Focus on critical or high findings that was identifies in analysis named “Ghostcat”.

1. What is the affected Port number

- Port 8009

2. What is the affected protocol

- Transmission Control Protocol (TCP)

3. What is the CVSS Score of vulnerability found

- 9.8 (CRITICAL)

4. Can you find any exploit related to this vulnerability?

Vulnerability Information

CPE: cpe:/a:apache:tomcat
Exploit Available: true
Exploit Ease: Exploits are available
Patch Pub Date: March 1, 2020
Vulnerability Pub Date: March 1, 2020
Exploited by Nessus: true

5. Find CVE for this vulnerability.

- CVE-2020-1938 (Apache Software Foundation)
- CVE-2020-1745 (Red Hat, Inc.)